BUG BOUNTY & BUG HUNTING ROADMAP

A complete 16-phase master syllabus covering web security, API vulnerability assessment, and bounty hunting methodology.

PHASE 1 Computer & Internet Fundamentals

1. Computer Fundamentals
2. Operating System Fundamentals
3. Client-Server Architecture
4. Internet Fundamentals
5. How Websites Work
6. Domain Names
7. DNS Fundamentals
8. IP Addressing
9. HTTP & HTTPS
10. Request & Response Cycle
11. Cookies & Sessions
12. Browser Architecture

PHASE 2 Networking Fundamentals

1. OSI Model
2. TCP/IP Model
3. TCP and UDP
4. DNS Protocol
5. DHCP
6. ARP
7. Routing
8. Proxy Servers
9. VPN
10. SSL/TLS
11. Common Network Ports
12. Network Traffic Analysis

PHASE 3 Web Technologies

1. HTML Fundamentals
2. CSS Fundamentals
3. JavaScript Fundamentals
4. DOM Architecture
5. Browser Storage
6. Local Storage
7. Session Storage
8. Cookies
9. Same-Origin Policy
10. CORS
11. REST APIs
12. JSON
13. Authentication
14. Authorization
15. JWT
16. OAuth 2.0
17. SSO
18. WebSockets
19. GraphQL Fundamentals

PHASE 4 Bug Bounty Fundamentals

1. Bug Bounty Introduction
2. Vulnerability Disclosure Programs
3. Public Bug Bounty Programs
4. Private Bug Bounty Programs
5. Vulnerability Disclosure Policy (VDP)
6. Scope and Out-of-Scope Assets
7. Rules of Engagement
8. Bug Bounty Methodology
9. Reconnaissance Methodology
10. Vulnerability Validation
11. False Positive Identification
12. Impact Assessment
13. Responsible Disclosure
14. Bug Bounty Report Writing

PHASE 5 Reconnaissance & Information Gathering

1. Passive Reconnaissance
2. Active Reconnaissance
3. Domain Enumeration
4. Subdomain Enumeration
5. DNS Enumeration
6. IP Address Discovery
7. ASN Enumeration
8. Port Scanning
9. Service Detection
10. Technology Fingerprinting
11. Directory Enumeration
12. Virtual Host Enumeration
13. Google Dorking
14. GitHub Reconnaissance
15. JavaScript File Reconnaissance
16. Historical URL Discovery
17. Cloud Asset Discovery
18. Attack Surface Mapping

PHASE 6 Authentication Vulnerabilities

1. Authentication Fundamentals
2. Broken Authentication
3. Weak Password Policies
4. Username Enumeration
5. Password Reset Vulnerabilities
6. Account Takeover
7. Multi-Factor Authentication (MFA) Bypass
8. OTP Vulnerabilities
9. Session Management Vulnerabilities
10. Session Fixation
11. Session Hijacking
12. JWT Vulnerabilities
13. OAuth Misconfiguration
14. SSO Vulnerabilities
15. Remember Me Vulnerabilities

PHASE 7 Authorization Vulnerabilities

1. Authorization Fundamentals
2. Broken Access Control
3. IDOR
4. BOLA
5. BFLA
6. Privilege Escalation
7. Horizontal Privilege Escalation
8. Vertical Privilege Escalation
9. Forced Browsing
10. Insecure Direct Object Reference
11. Multi-Tenant Authorization Issues
12. Role-Based Access Control (RBAC) Issues
13. Parameter-Based Authorization Bypass

PHASE 8 Injection Vulnerabilities

1. SQL Injection (SQLi)
2. Blind SQL Injection
3. Time-Based SQL Injection
4. Union-Based SQL Injection
5. Error-Based SQL Injection
6. NoSQL Injection
7. OS Command Injection
8. LDAP Injection
9. XPath Injection
10. XML Injection
11. Server-Side Template Injection (SSTI)
12. CRLF Injection
13. Header Injection
14. HTTP Parameter Pollution

PHASE 9 Cross-Site Scripting (XSS)

1. XSS Fundamentals
2. Reflected XSS
3. Stored XSS
4. DOM-Based XSS
5. Blind XSS
6. Mutation XSS
7. HTML Injection
8. Context-Based XSS
9. Filter Bypass Concepts
10. Content Security Policy (CSP) Bypass

PHASE 10 Server-Side Vulnerabilities

1. Server-Side Request Forgery (SSRF)
2. Server-Side Template Injection
3. Local File Inclusion (LFI)
4. Remote File Inclusion (RFI)
5. Path Traversal
6. File Upload Vulnerabilities
7. Insecure Deserialization
8. XML External Entity (XXE)
9. Remote Code Execution (RCE)
10. Server-Side Information Disclosure
11. Race Conditions
12. Request Smuggling
13. HTTP Host Header Injection
14. Open Redirect
15. Server-Side Parameter Pollution

PHASE 11 Client-Side Vulnerabilities

1. Cross-Site Request Forgery (CSRF)
2. Clickjacking
3. DOM Clobbering
4. Prototype Pollution
5. CORS Misconfiguration
6. PostMessage Vulnerabilities
7. Client-Side Path Traversal
8. Client-Side Information Disclosure
9. Open Redirect
10. Subdomain Takeover
11. Web Cache Poisoning
12. Web Cache Deception

PHASE 12 API Security Testing

1. API Fundamentals
2. REST API Security
3. GraphQL Security
4. API Authentication
5. API Authorization
6. BOLA
7. BFLA
8. Mass Assignment
9. Excessive Data Exposure
10. Rate Limiting Issues
11. API Key Exposure
12. JWT Misconfiguration
13. API Versioning Issues
14. Improper Inventory Management
15. Unrestricted Resource Consumption

PHASE 13 Business Logic Vulnerabilities

1. Business Logic Errors
2. Price Manipulation
3. Coupon Manipulation
4. Payment Logic Flaws
5. Race Conditions
6. Workflow Bypass
7. Limit Bypass
8. Quantity Manipulation
9. Referral Abuse
10. Account Takeover Logic Flaws
11. Privilege Escalation Through Business Logic
12. Multi-Step Process Bypass

PHASE 14 Advanced Vulnerabilities

1. Web Cache Poisoning
2. Web Cache Deception
3. HTTP Request Smuggling
4. Host Header Attacks
5. Prototype Pollution
6. Deserialization Attacks
7. Advanced SSRF
8. Advanced XXE
9. Advanced Race Conditions
10. WebSocket Vulnerabilities
11. OAuth Advanced Attacks
12. JWT Advanced Attacks
13. Subdomain Takeover
14. Cloud Misconfigurations
15. Serverless Security Issues

PHASE 15 Tools & Practical Testing Stack

1. Burp Suite **2. OWASP ZAP** **3. Nmap** **4. httpx** **5. Subfinder** **6. Amass** **7. Assetfinder** **8. Naabu** **9. Nuclei**
10. Katana **11. ffuf** **12. Gobuster** **13. Feroxbuster** **14. Gau** **15. Waybackurls** **16. Dalfox** **17. SQLmap**
18. Gitleaks **19. TruffleHog** **20. Postman** **21. Caido**

PHASE 16 Professional Bug Bounty Skills

1. Vulnerability Chaining
2. Impact Analysis
3. CVSS Scoring
4. CVE Fundamentals
5. CWE Classification
6. Proof of Concept (PoC) Development
7. Vulnerability Reproduction
8. Report Writing
9. Evidence Collection
10. Duplicate Report Avoidance
11. Responsible Disclosure
12. Bug Bounty Platform Management
13. Professional Research Methodology